# ISO/IEC 27001:2022

# ISMS Project Documentation

## Information Security Management System

## Governance, Risk, and Compliance Portfolio

**Prepared By: Hossam El-Deen Mohamed Shebl**
Cyber security GRC analyst | Cairo, Egypt

**Document Contents**

- Clauses 4-10 requirements.
- Risk register.
- Internal Audit checklist.
- PDCA mapping
- Statement of applicability

## Executive Summary:

This document presents a complete ISO/IEC 27001:2022 Information Security Management System (ISMS) project, built as a practical GRC portfolio demonstrating hands-on knowledge of governance, risk, and compliance. It covers all mandatory clauses (4–10), the PDCA continual improvement cycle, a full Risk Register, Statement of Applicability (SoA), and Internal Audit Checklist — the core deliverables required for ISO 27001 certification readiness.

## Risk Register Summary:

| Risk Level | Count | Risk IDs | Primary treament |
|---|---|---|---|
| High | 5 | R-001, R-002, R-003, R-005, and R-009 | Mitigate via MFA, email filtering, backup testing, cloud policy |
| Medium | 5 | R-004, R-006, R-007, R-008, and R-010 | Mitigate via encryption, network controls, TPRM, physical security |
| Low | 1 | R-011 | Mitigate via access control |

## Internal Audit Summary:

| Finding Type | Count | Clauses affected | Action required |
|---|---|---|---|
| Conformity (C) | 13 | 4.1, 4.2, 4.3, 5.1, 5.2, 6.1, 6.3, 7.1, 7.2, 8.2, 9.1, 9.2, 9.3 | No action required — maintain current controls |
| NonConformtiy (NC) | 2 | 6.2, 7.5 | Corrective action required — SoA approval and document review process |
| OPP for Improvements (OFI) | 3 | 5.3, 7.3, 10.2 | RACI review, phishing training improvement, open CARs closure |

## Clauses 4-10: ISMS requirements.

Each clause of ISO 27001 defines a mandatory requirement for establishing and maintaining the ISMS. The table below maps each clause to its key requirement, organizational action, practical example, and PDCA phase.

| ISO/IEC 27001:2022 — Clauses 4 to 10 — ISMS Requirements | | | | | |
|---|---|---|---|---|---|
| Clause | Clause Name | Key Requirement | What the Organization Must Do | Practical Example | PDCA Phase |
| 4.1 | Context of the Organization. | Understand internal & external issues. | Identify factors that affect the ISMS: legal, regulatory, competitive, cultural. | A company in Egypt maps external issues: CBE regulations, Egyptian data protection laws, cyber threat landscape, Market competation. Internal Issues: Security Culture, Policies and process. | Plan |
| 4.2 | Needs of Interested Parties. | Identify the interested parties & their requirements. | List all parties whether they're Internal: (employees, Internal auditors, C-level management) or they're External: (regulators, clients, suppliers) and their security expectations. | Bank lists: CBE (regulator), corporate clients, auditors (compliance evidence). | Plan |
| 4.3 | Scope of the ISMS. | Define what is covered by the ISMS, consider the: External and Internal Issue referred in 4.1, The requirements In 4.2 and Interfaces and dependecies between | Document the boundaries: which systems, sites, processes, and departments are in scope. | Scope: 'All IT systems supporting retail banking operations in Cairo HQ'. | Plan |
| 4.4 | ISMS Establishment. | Establish, implement, maintain & improve the ISMS. | Create and operate the ISMS according to the standard this is the overarching commitment. | The organization formally establishes the ISMS by creating policies, assigning roles, and beginning risk assessments. | Plan |
| 5.1 | Leadership & Commitment. | Top management must actively support the ISMS. | Management approves the ISMS policy, allocates resources, promotes security culture, and ensures the ISMS acheives its intended outcomes. | CEO signs the Information Security Policy; CISO reports directly to board. | Plan |
| 5.2 | Information Security Policy. | Define and communicate the IS policy. | Create a high-level policy statement covering objectives, commitment, and improvement. | Published policy: 'We protect the confidentiality, integrity, and availability of all information assets'. | Plan |
| 5.3 | Roles & Responsibilities. | Management assigns ISMS roles clearly. | Define who is responsible for what: CISO, IT, risk owners, process owners. | CISO owns the ISMS; department heads own risks in their area; all staff follow the policy. | Plan |
| 6.1 | Risk Assessment. | Identify, analyze and evaluate information security risks. | Define risk criteria, identify assets and threats, assess likelihood & impact, prioritize risks. | Risk: Phishing attack on staff email — Likelihood: High, Impact: High, Risk Level: High. | Plan |
| 6.2 | Risk Treatment. | Select and apply controls to treat risks. | Choose treatment: Mitigate/ Accept / Transfer / Avoid — document in Risk Treatment Plan — Produce a SoA. | Critical phishing risk → Mitigate: implement email filtering, MFA, and phishing awareness training. | Plan |
| 6.3 | Information Security Objectives. | Set measurable security objectives — and communicate It with the interested parties. | Define targets aligned to the policy and track progress — document In INFO SEC objectives. | Objective: Reduce phishing click rate from 15% to below 5% within 6 months. | Plan |

| ISO/IEC 27001:2022 — Clauses 4 to 10 — ISMS Requirements | | | | | |
|---|---|---|---|---|---|
| Clause | Clause Name | Key Requirement | What the Organization Must Do | Practical Example | PDCA Phase |
| 7.1 | Resources. | Determine, and Provide necessary resources. | Allocate people, tools, budget, and infrastructure needed for the ISMS. | Budget approved for SIEM tool, security awareness platform, and ISO 27001 consultant. | Do |
| 7.2 | Competence. | Determine the necessary Competence, and Ensure staff have required skills. | Identify competency gaps and provide training or hire accordingly, and then evaluate the effectiveness of them. | Security team trained on ISO 27001; annual refresher for all staff, and HR hired Competent employees. | Do |
| 7.3 | Awareness. | Staff must be aware of the ISMS. | Communicate the IS policy, their contribution, and consequences of non-compliance. | Monthly security awareness emails; quarterly phishing simulation exercises, and provides SETA program for all staff regularly. | Do |
| 7.4 | Communication. | Define internal and external communication. | Who communicates what, when, and to whom regarding the ISMS. | Internal: security incidents reported to CISO within 1 hour. External: breaches notified to regulator within 72 hours. | Do |
| 7.5 | Documented Information. | Creat, Update, and Control documents and records. | Maintain required documents (policies, procedures, records) and control their versioning. | Policy v2.1 approved by CEO on 01/03/2025; stored in GoogleDrive with access controls only to limited users. | Do |
| 8.1 | Operatiol Planning and Control. | Plan, Implement and control ISMS processes. | Implement risk treatment plans referred in 6.2 and manage changes to ensure consistent operation. | Quarterly review of open risks and evaluate them; change management process for new systems. | Do |
| 8.2 | Information Security Risk Assessment. | Perform risk assessments at planned intervals. | Conduct formal risk assessments at least semi-annually or when significant changes occur. | Semi-annual risk assessment scheduled every January and July; ad-hoc assessment triggered when new cloud system is introduced. | Do |
| 8.3 | Information Security Risk Treatment. | Implement the risk treatment plan. | Apply selected controls from Annex A and document implementation. | MFA implemented for all privileged accounts; firewall rules updated; results documented in Risk Register. | Do |
| 9.1 | Monitoring & Measurement. | Monitor, and Measure the ISMS performance. | Define what to measure, how, when, and who analyzes results. | Monthly KPI report: number of incidents, patch compliance %, phishing click rate — reviewed by CISO. | Check |
| 9.2 | Internal Audit. | Conduct internal audits of the ISMS at planned intervals. | Plan (Frequency, methods, Audit criteria and auditors) and perform audits to verify ISMS is conforming and effective— retain documentetd as evidence of the audit programee. | Annual internal audit covering all clauses; findings reported to management; corrective actions tracked. | Check |
| 9.3 | Management Review. | Top management reviews the ISMS at planned Internvals. | Formal management review meetings to ensure the ISMS is suitable, adqeuacy and effective — and to produce defined output. | Semi-annual management review: review audit results, risks, objectives, resources — minutes recorded. | Check |
| 10.1 | Continual Improvement. | Continuously improve the ISMS. | Identify opportunities for improvement and implement them systematically. | After phishing simulation showed 12% click rate, new training module rolled out — target 5% next quarter. | Act |
| 10.2 | Nonconformity & Corrective Action. | Address nonconformities and prevent recurrence. | When something goes wrong: contain it, find root cause, fix it, verify fix is effective. | Audit found missing access reviews → Root cause: no Policy defined → Fix: quarterly access review procedure created. | Act |

## PDCA Cycle Mapped to ISMS Activities:

The PDCA (Plan-Do-Check-Act) cycle is the continual improvement engine of ISO 27001. Every ISMS activity maps to one of the four phases, ensuring the system evolves and improves over time.

**ISO/IEC 27001:2022 — PDCA Cycle Mapped to ISMS Activities**

| PDCA Activity | ISO 27001 Clause | ISMS Action | Inputs | Outputs | Practical Example |
|---|---|---|---|---|---|
| Define ISMS scope | 4.3 | Determine what the ISMS will cover. | Business context, stakeholder needs. | Scope statement document. | All IT systems at Cairo HQ supporting retail banking operations'. |
| Establish IS Policy | 5.2 | Write and approve the information security policy. | Leadership commitment, legal requirements. | Signed Information Security Policy v1.0. | CEO approves policy stating commitment to CIA triad. |
| Conduct Risk Assessment | 6.1 | Identify assets, threats, vulnerabilities; score likelihood & impact. | Asset inventory, threat landscape. | Risk Register with scored risks. | Email server identified as critical asset; phishing scored as High risk. |
| Define Risk Treatment | 6.2 | Select controls from Annex A to treat identified risks. | Risk Register. | Risk Treatment Plan, SoA (Statement of Applicability). | For phishing risk: implement MFA, email filtering, and awareness training. |
| Set Security Objectives | 6.3 | Define measurable targets aligned to the IS policy. | Risk treatment decisions, policy. | Documented security objectives with KPIs. | Reduce unauthorized access incidents by 50% within 6 months. |
| Allocate Resources | 7.1 | Provide budget, tools, and trained personnel. | Management decisions, risk treatment plan. | Resource allocation plan, approved budget. | $50K budget approved for SIEM and security awareness platform. |
| Implement Controls | 8.3 | Deploy and configure selected Annex A controls. | Risk Treatment Plan, SoA. | Implemented controls, configuration records. | MFA enabled on all 200 user accounts; firewall rules updated. |
| Run Awareness Training | 7.3 | Deliver security training to all relevant staff. | Competency gaps identified. | Training completion records, awareness metrics. | 100% of staff complete annual security awareness training by Q1. |
| Manage Operations | 8.1 | Execute day-to-day ISMS processes and manage changes. | Operational plans, change requests. | Incident logs, change records, operational reports. | Monthly patching cycle completed; 3 incidents logged and resolved. |

| PDCA Activity | ISO 27001 Clause | ISMS Action | Inputs | Outputs | Practical Example |
|---|---|---|---|---|---|
| Monitor KPIs | 9.1 | Track security metrics and measure ISMS effectiveness. | Defined measurement criteria. | Monthly KPI dashboard, performance reports. | Phishing click rate: Jan 15% → Feb 12% → Mar 9% — trending down. |
| Conduct Internal Audit | 9.2 | Audit ISMS against ISO 27001 requirements. | Audit plan, clause checklist. | Audit report with findings and nonconformities. | Clause 7.5 finding: 3 policies not reviewed in 12 months — minor nonconformity raised. |
| Management Review | 9.3 | Hold formal review with leadership to assess ISMS status. | Audit results, KPIs, incident data, risks. | Management review minutes, decisions on resources and improvements. | Board meeting: ISMS performing well; approved additional headcount for security team. |
| PDCA Activity | ISO 27001 Clause | ISMS Action | Inputs | Outputs | Practical Example |
| Address Nonconformities | 10.2 | Investigate root cause of issues; implement corrective actions. | Audit findings, incident reports. | Corrective Action Report (CAR), updated procedures. | Root cause: no process for policy review → Fix: annual review calendar created and assigned. |
| Implement Improvements | 10.1 | Take actions to continually improve the ISMS. | Performance data, review outputs. | Updated plans, new controls, improved processes. | New phishing simulation platform implemented after click rate failed to meet target. |
| Update Risk Register | 6.1 / 8.2 | Reassess risks based on changes, incidents, and audit results. | Change log, incident data, audit findings. | Updated Risk Register, revised treatment plans. | New cloud migration project triggers risk reassessment; 5 new risks added to register. |

## Information Security Risk Register:

The Risk Register is the central GRC document for managing information security risks. Each risk is scored using Likelihood × Impact (1–5 scale). Risk levels: High = 13–25, Medium = 6–12, Low = 1–5. All risks are treated via Annex A controls.

ISO/IEC 27001:2022 — Information Security Risk Register

| RID | Asset | Asset Owner | Threat | Vulnerability | Likelihood (1-5) | Impact (1-5) | Risk Score (LxI) | Risk Level | Treatment Option | Annex A Control | Control Owner | Status | Review Date |
|---|---|---|---|---|---|---|---|---|---|---|---|---|---|
| R-001 | Email System | IT Manager | Phishing Attack | Lack of email filtering & user awareness | 4 | 5 | 20 | High | Mitigate | A.8.23 Web filtering / A.6.3 Awareness | Security Team | In Progress | 30/09/2026 |
| R-002 | User Accounts | IT Manager | Unauthorized Access | Weak password policy, no MFA | 4 | 5 | 20 | High | Mitigate | A.5.17 Authentication / A.8.5 Privileged access | IT Manager | Completed | 30/09/2025 |
| R-003 | Customer Database | Data Owner | Data Breach | Unencrypted data at rest | 3 | 5 | 15 | High | Mitigate | A.8.24 Cryptography | IT Manager | In Progress | 31/07/2026 |
| R-004 | Network Infrastructure | Network Admin | DDoS Attack | No rate limiting or traffic filtering | 3 | 4 | 12 | Medium | Mitigate | A.8.20 Network security | Network Admin | Planned | 31/08/2026 |
| R-005 | Backup Systems | IT Manager | Ransomware | Backups not tested / not isolated | 4 | 5 | 20 | High | Mitigate | A.8.13 Backup | IT Manager | In Progress | 30/09/2026 |
| R-006 | Third Party Vendor | Procurement | Supply Chain Attack | No vendor security assessment process | 3 | 4 | 12 | Medium | Mitigate | A.5.19 Supplier relationships | GRC Analyst | Planned | 30/09/2026 |
| R-007 | Physical Server Room | Facilities | Unauthorized Physical Access | No CCTV, no access log | 3 | 4 | 12 | Medium | Mitigate | A.7.2 Physical entry | Facilities Mgr | Planned | 31/08/2026 |
| R-008 | Staff Laptops | HR / IT | Theft or Loss | No full disk encryption, no remote wipe | 3 | 4 | 12 | Medium | Mitigate | A.8.1 Endpoint devices | IT Manager | Planned | 30/09/2026 |
| R-009 | Cloud Services (AWS) | Cloud Team | Misconfiguration | No cloud security policy or review process | 4 | 4 | 16 | High | Mitigate | A.8.23 / A.5.23 Cloud security | Cloud Team | In Progress | 31/07/2026 |
| R-010 | HR Records | HR Manager | Insider Threat | Excessive access privileges for HR staff | 2 | 4 | 8 | Medium | Mitigate | A.5.18 Access rights | HR Manager | Planned | 30/09/2026 |
| R-011 | Test Environment Server | IT Department | Unauthorized access | Weak password on test account | 1 | 3 | 3 | Low | Mitigate | A.9 Access control | IT Manager | Planned | 30/12/2026 |

## Statement of Applicability (SOA):

The Statement of Applicability is a mandatory ISO 27001 document listing which Annex A controls are applicable, why they are included, and their current implementation status. It links directly to the Risk Register and Risk Treatment Plan.

| ISO/IEC 27001:2022 — Statement of Applicability (SoA) — Selected Controls | | | | | | |
|---|---|---|---|---|---|---|
| Control Ref | Control Name | Applicable? (Yes/No) | Justification for Inclusion | Implementation Status | Risk Ref | Notes |
| A.5.1 | Information security policies | Yes | Mandatory — defines the security direction for the whole organization | Completed | All | Approved by CEO; reviewed annually |
| A.5.15 | Access control | Yes | Required to prevent unauthorized access to systems and data | In Progress | R-002 | Role-based access control being implemented |
| A.5.17 | Authentication information | Yes | Required to enforce strong password and MFA policies | Completed | R-002 | MFA deployed for all privileged accounts |
| A.5.19 | Information security in supplier relationships | Yes | Third parties handle customer data — TPRM process required | Planned | R-006 | Vendor assessment questionnaire in development |
| A.5.23 | Information security for use of cloud services | Yes | Organization uses AWS — cloud security controls required | In Progress | R-009 | Cloud security policy being drafted |
| A.6.3 | Information security awareness, education and training | Yes | All staff must understand their security responsibilities | Completed | R-001 | Annual training + quarterly phishing simulations |
| A.7.2 | Physical entry controls | Yes | Server room and office security must be controlled | Planned | R-007 | CCTV and access log system planned for Q3 |
| A.8.1 | User endpoint devices | Yes | Laptops and mobiles are high-risk — encryption and MDM needed | Planned | R-008 | MDM solution evaluation in progress |

# Internal Audit Checklist: Clauses 4 – 10

The internal audit verifies that the ISMS is conforming to ISO 27001 requirements and is operating effectively. Findings are classified as: C = Conformity, NC = Nonconformity (requires corrective action), OFI = Opportunity for Improvement.

| ISO/IEC 27001:2022 — Internal Audit Checklist (Clauses 4–10) | | | | | | |
|---|---|---|---|---|---|---|
| Clause | Requirement | Audit Question | Evidence Required | Finding (C / NC / OFI) | Notes | Auditor |
| 4.1 | Context | Has the organization identified internal and external issues relevant to the ISMS? | Context analysis document, SWOT or PESTLE records | C | Context document last updated Jan 2025 | H. Shebl |
| 4.2 | Interested Parties | Are stakeholder requirements documented and kept up to date? | Stakeholder register, requirements list | C | 10 stakeholders identified including CBE and customers | H. Shebl |
| 4.3 | Scope | Is the ISMS scope clearly defined and documented? | Scope statement document | C | Scope covers Cairo HQ IT systems | H. Shebl |
| 5.1 | Leadership | Does top management demonstrate commitment to the ISMS? | Meeting minutes, signed policy, resource allocations | C | CEO signed IS Policy; quarterly security review held | H. Shebl |
| 5.2 | Policy | Is the IS policy approved, communicated, and available to staff? | Published policy, communication records, staff acknowledgment | C | Policy on intranet; 95% staff acknowledged | H. Shebl |
| 5.3 | Roles | Are ISMS roles and responsibilities clearly assigned? | Org chart, RACI matrix, job descriptions | OFI | RACI exists but not reviewed since 2023 | H. Shebl |
| 6.1 | Risk Assessment | Has a formal risk assessment been performed using a defined methodology? | Risk Register, methodology document, risk criteria | C | Risk Register contains 10 risks; methodology documented | H. Shebl |
| 6.2 | Risk Treatment | Is there a Risk Treatment Plan linked to the Risk Register? | Risk Treatment Plan, SoA | NC | SoA drafted but not formally approved by management | H. Shebl |
| 6.3 | Objectives | Are information security objectives documented and measurable? | Objectives document with KPIs and owners | C | 5 objectives defined with monthly KPI tracking | H. Shebl |
| 7.1 | Resources | Are adequate resources provided for the ISMS? | Budget records, staffing records, tool licenses | C | Security budget approved; SIEM license active | H. Shebl |
| ISO/IEC 27001:2022 — Internal Audit Checklist (Clauses 4–10) | | | | | | |
| Clause | Requirement | Audit Question | Evidence Required | Finding (C / NC / OFI) | Notes | Auditor |
| 7.2 | Competence | Are staff competencies assessed and training provided? | Training records, competency matrix | C | Annual training completed; matrix reviewed Q1 | H. Shebl |
| 7.3 | Awareness | Are staff aware of the IS policy and their ISMS responsibilities? | Awareness training records, phishing simulation results | OFI | Phishing click rate at 12% — above 5% target | H. Shebl |
| 7.5 | Documentation | Are documents controlled, versioned, and accessible? | Document register, version history, access controls | NC | 3 procedures not reviewed in over 12 months | H. Shebl |
| 8.2 | Risk Assessment | Are risk assessments conducted at planned intervals or after significant changes? | Risk assessment schedule, dated risk records | C | Annual assessment Jan 2025 completed | H. Shebl |
| 9.1 | Monitoring | Are ISMS performance metrics defined and reported? | KPI dashboard, monitoring reports | C | Monthly KPI report reviewed by CISO | H. Shebl |
| 9.2 | Internal Audit | Is there an internal audit programme with documented results? | Audit plan, audit reports, corrective actions | C | This audit (first of 2025) | H. Shebl |
| 9.3 | Management Review | Has a management review been conducted with required inputs? | Management review minutes, agenda, actions | C | Review held Feb 2025; minutes on file | H. Shebl |
| 10.2 | Corrective Action | Are nonconformities addressed with root cause analysis and corrective actions? | Corrective Action Reports (CARs), closure evidence | OFI | 2 open CARs from previous audit not yet closed | H. Shebl |

| Legend | |
|---|---|
| C | Conformity — requirement met |
| NC | Nonconformity — requirement not met |
| OFI | Opportunity for Improvement |